

4.11 - Threat modeling: STRIDE e árvores de ataque

Encontrar a ameaça antes que ela encontre você

A primeira sessão de threat modeling

- **Antes de assinar com o cliente farmacêutico**
 - Primeira sessão estruturada de STRIDE na empresa

LUNALOG

Antes de assinar o contrato com o cliente farmacêutico, a LunaLog realizou sua primeira sessão de threat modeling. O exercício com STRIDE identificou três ameaças críticas que ninguém havia mapeado: um motorista podia forjar a localização GPS, classificada como tampering; não existia trilha de auditoria imutável para confirmações de entrega, classificada como repudiation; e o endpoint de integração ficava exposto sem autenticação por IP, classificado como elevation of privilege. Roberto ficou surpreso ao ver três incidentes futuros sendo evitados sem que uma linha de código fosse escrita. Threat modeling deixou de ser teoria e virou ritual de design na LunaLog.

Threat modeling: pensar como atacante

Identificar ameaças ainda no design

- **Identificar ameaças ainda na fase de design**
 - Mais barato corrigir no diagrama que em produção
- **Mapear ativos, fronteiras de confiança e fluxos**
 - Onde o dado cruza uma fronteira é onde o risco vive
- **Para cada componente, perguntar o que pode dar errado**
 - Estruturar a pergunta evita esquecer categorias
- **O objetivo é priorizar mitigação, não listar tudo**

STRIDE é um checklist contra o esquecimento

- Sem framework, a equipe só vê as ameaças óbvias
- STRIDE força olhar cada categoria, uma a uma

Aplique STRIDE em cima de um diagrama de fluxo de dados. Para cada elemento que cruza uma fronteira de confiança, percorra as seis letras.

- O resultado é uma lista priorizável de mitigações

STRIDE: seis categorias de ameaça

- **Spoofing: fingir ser quem não é**
 - Mitigação por autenticação forte
- **Tampering: alterar dado ou código**
 - Mitigação por integridade e assinatura
- **Repudiation: negar uma ação realizada**
 - Mitigação por log imutável e auditoria
- **Information disclosure, denial of service, elevation of privilege**
 - Confidencialidade, disponibilidade e menor privilégio respondem

| Árvore de ataque: dados de outro tenant

PSEUDOCODE

```
Objetivo: ler entregas de outra transportadora
|— Manipular o ID do tenant na URL
|   |— Mitigado por: checagem de tenant no backend
|— Forjar um JWT com outro tenant
|   |— Mitigado por: validar assinatura e claims
|— Abusar de endpoint de integracao aberto
|   |— Mitigado por: autenticacao e mTLS
```



Threat modeling encontra as ameaças que você consegue imaginar. Mas e a estrutura do próprio sistema, ela resiste a essas ameaças por padrão, ou depende de cada desenvolvedor lembrar de fazer a coisa certa? Existe um conjunto de princípios que torna a segurança parte do design, não um remendo aplicado depois.

Secure by design e OWASP para arquitetos